

Understanding Ransomware Actions Through Behavioral Feature Analysis

Abstract—Crypto ransomware attacks have substantially increased in recent years, and owing to their highly profitable nature, this growth will evidently escalate in the future. To better understand this malware and help developers of ransomware detection systems build more robust and reliable solutions, this study investigates ransomware actions during the destruction phase through behavioral feature analysis. We used a dataset with 1524 samples and 30 967 features representing the actions conducted using 582 types of ransomware and 942 good applications (goodware). Six representative and widely used classification algorithms were applied as auxiliary tools to investigate the behavior of these attacks: Naive Bayes (NB), K-Nearest Neighbors (KNN), Logistic Regression (LR), Random Forest (RF), Stochastic Gradient Descent (SGD), and Support Vector Machine (SVM). We achieved an accuracy of 98.48%, balanced accuracy of 98.35%, precision of 98.17%, recall of 97.82%, F-measure of 97.98%, and ROC AUC of 99.87% by using RF for 462 features of the resultant dataset. We propose a new criterion to determine the feature group relevance and a method to distinguish the features that are most related to ransomware and goodware. Our main conclusions are as follows: Application Programming Interface (API) calls are the most relevant feature group, achieving alone a balanced accuracy of 96.49%; native encryption Windows APIs are not crucial for ransomware classification; and the most significant features of ransomware tend to involve handling the thread/process, physical memory operation, and communication, whereas goodware features are more likely to indicate virtual memory, files, directories, and resource operations.

Index Terms—Ransomware detection, feature analysis, behavioral analysis, machine learning, cybersecurity.

In general, protection software solutions are capable of defending systems against previously known ransomware. These methods are comparisons based on signatures that already exist in a database. However, in attacks hitherto unknown (zero-day), current solutions present difficulties in the accuracy of detection and return high rates of false positives and false negatives [6], [7]. The majority of these approaches use Machine Learning (ML) models that are built using a set of analysis features. ML-based ransomware detection systems use structural features, behavioral features, or both. Structural features are obtained through static analysis of ransomware binaries, in which the code of a suspicious program is inspected to recognize malicious patterns in the computer system. The major advantage of this approach is its ability to identify harmful instructions before the program is run; however, this approach is more susceptible to deception through obfuscation, polymorphism, encryption, and anti-disassembler techniques. By contrast, behavioral features are obtained through dynamic analysis, in which a suspicious program runs in an isolated environment and its behavior is monitored during its execution, seeking malicious action patterns in the Operating System (OS). The advantage of this type of analysis is that it makes evasion techniques difficult to implement. Moreover, it allows us to analyze and understand how these dangerous programs operate in an OS. Nevertheless, this approach is typically slower and more dangerous [4], [5], [8].

Therefore, this paper presents a behavioral feature analysis to improve the understanding of crypto ransomware behavior during the destruction phase in Windows OS and to support developers of anti-malware systems to build more solid and reliable solutions. To achieve these goals, we formulated and answered four questions: 1) Should all groups of features be equally considered, 2) what changes from ransomware to goodware, 3) what are the most relevant APIs, and 4) where are the encryption APIs?. We used a dataset containing 30 967 behavioral actions of 582 ransomware and 942 good applications (goodware) [12]. We first observed that APIs can be grouped based on Microsoft naming conventions, and then eliminated features with low variance and used six traditional classifiers as auxiliary tools to investigate the behavior of these attacks. In addition, this study proposes a new criterion to determine the relevance of each feature group and distinguish the features most associated with ransomware and goodware, which allows us to identify the behavior patterns of both classes.

The remainder of this paper is organized as follows. Section II presents related studies and their main results, advantages, and limitations. Section III describes the dataset, data preprocessing, feature selection, and evaluation metrics. In Section IV, we present our results and answer the questions formulated by investigating the main factors associated with ransomware behavior. Finally, Section V provides the conclusions obtained throughout the study and suggests future research directions.

RELATED WORKS

Alruhaily et al. [13], [14] analyzed the general behavior of malware to better understand the causes of misclassification. They formulated questions about the behavior of malware and answered them using feature selection techniques and classification algorithms. These types of studies are essential for improving solutions for malware detection systems. Nevertheless, Alruhaily et al. [13], [14] did not focus on a specific type of malware, which could lead to less accurate investigations.

In recent years, several studies have investigated the ransomware issues. Most of these are related to the detection and prevention of this type of attack. Recent studies have used only API calls in dynamic analysis to detect malicious ransomware behavior [15]–[19]. The studies in [20], [21] suggest that API features alone are adequate for detecting ransomwares. Kok et al. [22] proposed a pre-encryption detection algorithm (PEDA) that can detect Crypto ransomware in the pre-encryption stage when no encryption has been conducted using API features. They identified three APIs that appeared more in ransomware and 11 that were more related to goodware. A limitation of [22] is that feature groups other than the API were not analyzed. Furthermore, the proposed PEDA relies on the use of native encryption Windows APIs, as its initial analysis only

selects samples that contain APIs with the word "crypt"; thus, it is unable to detect ransomware that uses its own native encryption code.

Sgandurra et al. [12] proposed EldeRan, an ML approach to classifying ransomware based on behavior using the Regularized Logistic Regression (RLR) algorithm. They built and shared a dataset representing several Windows events such as API calls, file and directory operations, registry key modifications, and context (embedded strings). In addition, EldeRan used Mutual Information (MI) as feature selection method and achieved a detection rate of 96.34% using the top-400 features. The results were considered competitive with the top-5 anti-virus vendors. The authors also suggested that the most substantial group of features for classifying ransomware was REG, that is, registry key operation events, followed by API, STR, FILES_EXT (EXT), FILES, DIR, and DROP. The criterion used for evaluating the groups was the percentage of features remaining after feature selection; however, this may not be a good criterion for datasets with imbalanced feature groups.

In addition, using the dataset provided by [12], Abbasi et al. [23] proposed a dynamic analysis with a two-stage feature-selection method that considers the varying importance of each feature group in the dataset. To select an optimal number of features from each group and achieve better classification performance, the model applied MI for Stage I and Particle Swarm Optimization (PSO) for Stage II. They achieved an accuracy of 97.34% using the RLR classifier with 822 ± 59 features. They used the same criterion as in [12] to evaluate the groups and concluded that the API group was the most relevant, followed by REG, STR, EXT, DROP, FILES, and DIR.

Similarly, Khan et al. [24] used the dataset of [12] to evaluate their proposed DNAact-Ran, which is a digital DNA sequencing engine for detecting ransomware using ML. DNAact-Ran combines Multi-Objective Gray Wolf Optimization (MOGWO) and Binary Cuckoo Search (BCS) algorithms to select 26 features and then generates a vector that symbolizes a digital DNA sequence. This vector generates another vector based on the k-mer frequency, which is submitted to a linear regression model based on active learning training data. DNAact-Ran achieved an 87.9% detection accuracy, which is higher than the other algorithms compared; however, converting the features into the DNA sequence makes the features lose their meaning, making an in-depth study of them impossible. Hence, Khan et al. [24] could not analyze the relevance of the groups.

MATERIALS AND METHODS

This section describes the methodology, available dataset, data preprocessing, feature selection, tools, evaluation metrics, and experimental environment used in this study. Fig. 1 illustrates the high-level workflow of the proposed experiment. Our work aims to answer the four questions initially formulated by analyzing the available data (step 1), followed by preprocessing of data and feature selection (step 2). We use six representative classifiers to validate our model (step 3). We then split the resultant dataset into seven feature groups (step 4) to analyze each group's relevance according to our proposed criterion (step 5), and then to answer the first question (step 6). Subsequently, all groups of the resultant dataset are submitted to our proposed method to distinguish the features most associated with each class (step 7) using the highest scores found to answer the second question (step 8). Similarly, the API group is individually submitted to the method (step 9) to answer the third question (step 10). Finally, we search for native encryption Windows APIs in both the original and the resultant datasets (step 11), compare the occurrences in each other (step 12), and then submit the remaining features of the resultant dataset to our method (step 13) to answer the fourth question (step 14).

A. Data Description

The dataset used in this study contains 1524 samples: 582 ransomware and 942 goodware [12]. Each sample has 30 967

binary features, which were obtained by recording the events and operations executed by the samples through an analysis using the Cuckoo Sandbox¹. Seven different groups of features were categorized based on the behavior analysis of each program: API, DROP, REG, FILES, EXT, DIR, and STR. The API group indicates the API invocations of the executable file, DROP is an extension of the dropped files, REG is a registry key operation, FILES indicates file operations, EXT indicates the extensions of the files involved in file operations, DIR represents the directory operations, and STR is the embedded strings in the binary. Each sample was submitted to the analysis tool and all operations were cataloged. The dataset features are Boolean; consequently, each operation or event present in a given sample is represented by 1; otherwise, it is represented by 0.

Fig. 2 shows a 30-bin histogram of the probability distribution (on a logarithmic scale) of the sum of events for each dataset feature. The first bin indicates that the vast majority of features (98.46%) have between 0 and 50 events out of 1524 possibilities. Therefore, this dataset contains a massive concentration of features with little information.

This dataset is intended to represent the most popular versions of ransomware variants and typical applications designed for Windows OS. The ransomware samples belonging to different families are identified by their codes and were collected until 2016. Ransomware has evolved primarily in its dissemination techniques, that is, in the infection phase. There has also been an evolution of the communication and extortion phases; however, the destruction phase, which we propose to investigate, exhibits similar general behaviors [5]. Cybercrime clings to old techniques as long as they work, and thus, the data are still relevant. In [12], the authors provide a complete description of this dataset, which is one of the few datasets available to the public [25]. In [25], because none of the authors of the other papers in the survey made their datasets available to the public, it was noted that it is common practice to not share datasets in this specific area.